

INFORME DE SEGURIDAD Y CALIDAD EN EL DESARROLLO DE SOFTWARE

Plan de pruebas del Sistema de Gestión Atlas
Evaluación Parcial N°1 – Informe semestral, iteración 1 (Forma A)

ISY1102 – Seguridad y Calidad en el Desarrollo de Software

Sección 004V

Duoc UC – Escuela de Informática y Telecomunicaciones

Integrantes

Elías Robinson Delgado Manríquez
Rolando Aldana

Carrera: Ingeniería en Informática
Docente: Johnnathan René Cubillos Flores
Fecha: 15 de septiembre de 2026

ÍNDICE

1. Introducción.....	4
1.1 Contexto del software.....	4
1.2 Clasificación del producto.....	4
1.3 Propósito del plan de pruebas.....	4
1.4 Alcance.....	5
1.5 Estructura del informe.....	5
2. Criterios de calidad, seguridad y cumplimiento normativo.....	5
2.1 Criterios de calidad (ISO/IEC 25010).....	6
2.2 Criterios de seguridad.....	6
2.3 Cumplimiento normativo.....	7
2.4 Observación crítica sobre la ERS.....	8
3. Tipos de prueba y su justificación.....	9
3.1 Pruebas funcionales.....	9
3.2 Pruebas no funcionales.....	9
3.3 Pruebas de seguridad.....	10
3.4 Justificación de la selección.....	11
4. Estrategia de pruebas.....	11
4.1 Enfoque.....	11
4.2 Niveles y etapas del proceso.....	11
4.3 Priorización basada en riesgo.....	12
4.4 Criterios de entrada.....	12
4.5 Criterios de salida.....	13
4.6 Criterios de suspensión y reanudación.....	13
4.7 Gestión de defectos.....	13
5. Criterios de aceptación transversales.....	13
5.1 Criterios funcionales.....	13
5.2 Criterios de seguridad.....	14
5.3 Criterios no funcionales.....	14
5.4 Criterios de reglas de negocio.....	14
5.5 Severidad de defectos.....	14
6. Herramientas utilizadas.....	15
7. Recursos necesarios.....	16
7.1 Recursos humanos.....	16
7.2 Recursos técnicos.....	16
7.3 Entornos de prueba.....	17
8. Cronograma de ejecución.....	17
9. Diseño de casos de prueba.....	19
CP-01 – Inicio de sesión con credenciales válidas.....	19
CP-02 – Revocación del token al cerrar sesión.....	19
CP-03 – Registro de usuario y creación de empresa.....	20
CP-04 – Rol editor sin permisos de escritura.....	20
CP-05 – Aislamiento de datos entre empresas.....	21
CP-06 – Creación, validación y eliminación lógica de cliente.....	22
CP-07 – Cálculo del estado de un contrato.....	22
CP-08 – Carga de documento, almacenamiento y auditoría.....	23
CP-09 – Enlace compartido de documento.....	23
CP-10 – Protección contra inyección SQL, XSS y CSRF.....	24
CP-11 – Carga con 200 usuarios concurrentes.....	25
CP-12 – Usabilidad y accesibilidad con adultos mayores.....	25
CP-13 – Compatibilidad entre navegadores y dispositivos.....	26
10. Matriz de trazabilidad.....	27
10.1 Requerimientos funcionales y reglas de negocio.....	27
10.2 Requerimientos no funcionales.....	28

11. Análisis de cobertura y coherencia del plan.....	30
11.1 Cobertura cuantitativa.....	30
11.2 Distribución por tipo de prueba.....	30
11.3 Coherencia con los objetivos y estándares.....	31
11.4 Brechas identificadas y acciones.....	31
11.5 Conclusión.....	31

1. Introducción

1.1 Contexto del software

Atlas es una plataforma web desarrollada por CreaLab SpA para la gestión de clientes, contratos y documentos asociados, orientada a pequeñas y medianas empresas en Chile. Según la Especificación de Requerimientos de Software (ERS v1.1, Forma A), el sistema permite a usuarios registrados crear una empresa, administrar usuarios internos con roles diferenciados (administrador y editor), gestionar clientes con datos personales y bancarios, registrar contratos con documentos adjuntos y mantener un registro de auditoría de las acciones críticas.

La solución corresponde a una aplicación multicapa: un frontend SPA construido en React 19 con Material UI y Tailwind, una API REST en Node.js con Express 4 y una base de datos PostgreSQL. La autenticación se basa en JWT de corta vigencia con refresh token, las contraseñas se almacenan con bcrypt y todas las comunicaciones deben viajar sobre TLS. La ERS exige además que el sistema sea accesible desde computadores, tablets y móviles, con especial atención a la usabilidad para adultos mayores.

1.2 Clasificación del producto

Antes de definir las pruebas clasificamos Atlas según los tres ejes vistos en la asignatura:

Eje	Clasificación	Fundamento en la ERS
Calidad	Sistema de información empresarial transaccional (CRUD) de criticidad media-alta	Operaciones CRUD sobre clientes y contratos, umbrales de rendimiento (NFR-PERF) y disponibilidad 99,5 % (NFR-DIS-1)
Seguridad	Sistema multiusuario y multiempresa que trata datos personales y financieros	Datos bancarios de clientes (sección 2.2), control de acceso por rol (NFR-SEG-4), cifrado en reposo (NFR-SEG-3)
Cumplimiento normativo	Responsable de tratamiento de datos personales bajo la legislación chilena	NFR-SEG-8, RF-6 (auditoría), RB-2 (acceso restringido por empresa)

Por esta clasificación, el plan no se limita a comprobar que las funciones operen. También verifica que se respete la confidencialidad entre empresas, la integridad de los contratos y la trazabilidad que exige la normativa de protección de datos.

1.3 Propósito del plan de pruebas

Este plan define cómo vamos a verificar que Atlas cumple sus requerimientos funcionales, no funcionales y reglas de negocio, y cómo cada verificación se relaciona con los estándares de calidad y el marco legal. Buscamos asegurar que:

- Las funcionalidades esenciales (autenticación, registro, gestión de usuarios, clientes, contratos y auditoría) se comporten según lo especificado.
- Un usuario de una empresa no pueda acceder a datos de otra empresa y que el rol editor no pueda escribir información (RB-2, RB-4).
- Los datos personales y bancarios estén protegidos en tránsito y en reposo, y que cada acción crítica quede registrada.
- El sistema responda dentro de los umbrales definidos y sea utilizable por adultos mayores en distintos dispositivos y navegadores.
- Existan evidencias verificables que respalden el cumplimiento de la Ley 19.628, la Ley 21.719 y buenas prácticas reconocidas (ISO/IEC 25010, OWASP, WCAG).

1.4 Alcance

Dentro del alcance: módulos de autenticación y sesión (RF-1), registro y creación de empresa (RF-2), gestión de usuarios y roles (RF-3), gestión de clientes (RF-4), contratos y documentos (RF-5), auditoría (RF-6), API REST y requisitos no funcionales NFR-SEG, NFR-PERF, NFR-USAB, NFR-DIS y NFR-COMPAT, además de las reglas de negocio RB-1 a RB-5.

Fuera del alcance de esta iteración: pruebas sobre la infraestructura física del proveedor de hosting, el servicio de correo externo más allá de su integración, y auditorías legales formales, que corresponden a un asesor jurídico. Estos puntos quedan registrados como riesgos y dependencias.

1.5 Estructura del informe

El informe se organiza así: criterios de calidad, seguridad y cumplimiento normativo (sección 2); tipos de prueba y su justificación (sección 3); estrategia de pruebas (sección 4); criterios de aceptación y herramientas (secciones 5 y 6); recursos y cronograma (secciones 7 y 8); diseño de casos de prueba (sección 9); matriz de trazabilidad entre requerimientos, pruebas y controles normativos (sección 10); y análisis de cobertura y coherencia del plan (sección 11).

2. Criterios de calidad, seguridad y cumplimiento normativo

En Atlas, calidad, seguridad y cumplimiento legal están conectados. Por ejemplo, una falla en el control de acceso es un problema de calidad (el sistema no hace lo especificado), de seguridad (se pierde la confidencialidad) y legal (no se resguardan los datos personales). Por eso cada criterio de esta sección está ligado a un requerimiento de la ERS y a una referencia normativa.

2.1 Criterios de calidad (ISO/IEC 25010)

Característica ISO/IEC 25010	Criterio aplicado a Atlas	Requerimiento ERS	Métrica o evidencia
Adecuación funcional	Las operaciones CRUD, el cálculo de estado de contratos y la asignación de roles producen resultados correctos y completos	RF-1 a RF-6	100 % de casos funcionales de prioridad alta aprobados
Eficiencia de desempeño	Respuesta de operaciones CRUD simples bajo carga normal y carga de página principal en móvil	NFR-PERF-1, NFR-PERF-2, NFR-PERF-3	p95 < 300 ms; carga < 2 s; 200 usuarios concurrentes
Usabilidad	Interfaces legibles, controles grandes, flujos claros y mensajes de error comprensibles para adultos mayores	NFR-USAB-1 a 4, 3.1.1	SUS ≥ 70 con 5 usuarios mayores; 0 bloqueos mayores
Confiabilidad	Disponibilidad mensual, respaldo y recuperación ante fallos	NFR-DIS-1, NFR-SEG-7	Uptime ≥ 99,5 %; restauración de respaldo verificada
Seguridad	Confidencialidad, integridad, no repudio y autenticidad	NFR-SEG-1 a 9, RF-6	0 hallazgos críticos o altos en pentest
Compatibilidad	Funcionamiento en las dos últimas versiones de Chrome, Firefox, Safari y Edge	NFR-COMPAT-1	Matriz de navegadores sin defectos bloqueantes
Mantenibilidad	Código modular y pruebas automatizables en CI; migraciones seguras	NFR-DIS-2	Cobertura unitaria backend ≥ 70 %; migraciones reversibles
Portabilidad	Adaptación a distintos tamaños de pantalla	NFR-COMPAT-2	Vistas validadas en 360 px, 768 px y 1366 px

2.2 Criterios de seguridad

Tomamos como base la tríada confidencialidad, integridad y disponibilidad, y contrastamos cada criterio con OWASP Top 10 (2021) y OWASP ASVS 4.0 nivel 2, que es el nivel recomendado para aplicaciones con datos personales y financieros.

Ámbito	Criterio	Requerimiento ERS	Referencia
Protección de datos	TLS 1.2 o superior en todas las comunicaciones; cifrado de datos bancarios en reposo	NFR-SEG-1, NFR-SEG-3	OWASP A02 – Fallas criptográficas; ISO/IEC 27001 A.8.24
Autenticación	Contraseñas con bcrypt, política de 12 caracteres con complejidad, JWT de corta vigencia y revocación al cerrar sesión	RF-1.1, RF-1.2, NFR-SEG-2, NFR-SEG-9, 2.4	OWASP A07 – Fallas de identificación y autenticación

Ámbito	Criterio	Requerimiento ERS	Referencia
Control de acceso	Autorización validada en backend por rol y por pertenencia a empresa (aislamiento multiempresa)	RF-3.2, NFR-SEG-4, RB-2, RB-4, RB-5	OWASP A01 – Pérdida de control de acceso
Validación de entradas	Validación y saneamiento server-side; protección contra SQL Injection, XSS y CSRF; restricción de tipo y tamaño de archivos	RF-4.3, RF-5.2, NFR-SEG-5, 3.1.2	OWASP A03 – Inyección
Manejo de errores	Mensajes genéricos al usuario, sin trazas de pila ni detalles de base de datos	NFR-USAB-3, NFR-SEG-6	OWASP A05 – Configuración de seguridad incorrecta
Integridad y trazabilidad	Registro de auditoría inalterable de acciones críticas, con usuario, fecha, acción y recurso	RF-6.1, NFR-SEG-6	OWASP A09 – Fallas de registro y monitoreo
Enlaces compartidos	Enlaces de documento con token no predecible, expiración y posibilidad de revocación	RF-5.5	OWASP A01; principio de mínimo privilegio
Dependencias	Librerías sin vulnerabilidades conocidas críticas	Sección 4 (stack)	OWASP A06 – Componentes vulnerables

2.3 Cumplimiento normativo

Norma	Alcance en Atlas	Implicancia para las pruebas
Ley 19.628 sobre Protección de la Vida Privada	Atlas almacena nombres, contactos, RUT y datos bancarios de clientes de las pymes	Verificar que el acceso esté restringido a usuarios autorizados y que la información se utilice solo para su finalidad
Ley 21.719 (modifica la Ley 19.628 y crea la Agencia de Protección de Datos Personales; vigencia prevista para diciembre de 2026)	Introduce principios de licitud, finalidad, proporcionalidad, seguridad y responsabilidad proactiva, junto con deberes de reporte de brechas	Probar eliminación lógica y trazabilidad, minimización de datos en respuestas de la API y existencia de registros que demuestren medidas de seguridad
Ley 21.663, Ley Marco de Ciberseguridad	Atlas no es, en principio, un operador de importancia vital, pero sus clientes pueden serlo; se toma como referencia de seguridad por diseño y gestión de incidentes	Pruebas de seguridad antes de cada liberación y verificación del procedimiento de respuesta ante incidentes

Norma	Alcance en Atlas	Implicancia para las pruebas
Ley 21.459 sobre Delitos Informáticos	Tipifica el acceso ilícito a sistemas	Refuerza la necesidad de impedir y registrar accesos no autorizados; las pruebas de penetración se ejecutan solo con autorización formal
Ley 17.336 de Propiedad Intelectual	Uso de librerías de terceros (React, Express, MUI, etc.)	Revisión de licencias de dependencias (MIT u otras compatibles)
ISO/IEC 25010	Modelo de calidad de producto	Define las características evaluadas en 2.1
ISO/IEC 27001:2022	Gestión de seguridad de la información	Controles de cifrado, registro, respaldo y control de acceso
ISO/IEC/IEEE 29119	Proceso y documentación de pruebas	Estructura del plan, casos de prueba e informes
WCAG 2.1 nivel AA	Accesibilidad web	Contraste, etiquetas ARIA, navegación por teclado y tamaño de objetivos táctiles

2.4 Observación crítica sobre la ERS

Al revisar la ERS encontramos puntos que conviene aclarar con el cliente antes de ejecutar las pruebas, ya que afectan los criterios de aceptación:

- La ERS fija un tamaño de fuente de 12 px, lo que resulta insuficiente para el público adulto mayor declarado en el alcance. Se recomienda un mínimo de 16 px para texto base, en línea con NFR-USAB-1 y las pautas WCAG.
- El rol editor aparece definido como "sólo visualización", pero RF-4.1 indica que "los usuarios" pueden crear clientes. Se asume que prevalecen RF-3.2 y RB-4, es decir, que solo el administrador escribe datos.
- RF-5.2 menciona formatos DOC y PPT, pero no define tamaño máximo de archivo ni validación del contenido real (tipo MIME). Se propone un límite de 10 MB y validación por firma de archivo.
- RF-5.4 habla del estado "vence" sin definir el umbral. Se asume "por vencer" cuando faltan 30 días o menos para la fecha de término.
- NFR-USAB exige un "score de usabilidad mínimo aceptable" sin cifra. Se propone $SUS \geq 70$.
- RB-1 condiciona la unicidad del correo a una política no definida. Se prueba el comportamiento por defecto (correo único) y se deja parametrizable.

3. Tipos de prueba y su justificación

Separamos las pruebas en funcionales (qué hace el sistema) y no funcionales (cómo lo hace). Las de seguridad van en un grupo aparte por el tipo de datos que maneja Atlas y su peso en el cumplimiento legal.

3.1 Pruebas funcionales

Tipo	Propósito	Aplicación en Atlas	Requerimientos
Unitarias	Verificar la lógica aislada de funciones y servicios	Cálculo de estado del contrato, validación de RUT y formatos, política de contraseñas, generación de tokens	RF-4.3, RF-5.4, RF-1.1
Integración	Comprobar que frontend, API, base de datos y storage funcionan en conjunto	Creación de contrato con documento: API, tabla de contratos, storage interno y registro de auditoría	RF-5.1, RF-5.2, RF-5.3, RF-6.1
Sistema (end-to-end)	Validar flujos completos desde la interfaz	Registro, creación de empresa, invitación de usuario, alta de cliente y contrato	RF-2, RF-3, RF-4, RF-5
API / contrato	Verificar endpoints, códigos HTTP, esquemas JSON y validaciones server-side	Colección Swagger/Postman con pruebas de endpoints críticos, como exige la sección 3.1.2	3.1.2, NFR-SEG-5
Reglas de negocio	Confirmar que las restricciones del dominio se respetan	Un contrato asociado a un único cliente, editor de solo lectura, aislamiento entre empresas	RB-1 a RB-5
Regresión	Asegurar que un cambio no rompa funciones ya aprobadas	Suite automatizada en cada integración a la rama principal	Todos
Aceptación (UAT)	Confirmar con el cliente que el sistema cumple sus necesidades	Sesiones con usuarios de pymes sobre los flujos esenciales	Criterios de aceptación de cada RF

3.2 Pruebas no funcionales

Tipo	Propósito	Aplicación en Atlas	Requerimientos
Rendimiento – carga	Medir tiempos de respuesta bajo la carga esperada	200 usuarios concurrentes realizando listados y CRUD	NFR-PERF-1, NFR-PERF-3
Rendimiento – estrés y picos	Identificar el punto de quiebre y la recuperación	Incremento progresivo hasta degradación	NFR-PERF-3, NFR-DIS-1

Tipo	Propósito	Aplicación en Atlas	Requerimientos
Rendimiento frontend	Medir tiempo de carga percibido en móvil	Lighthouse con perfil de red móvil	NFR-PERF-2
Transferencia de archivos	Validar subida y descarga dentro del umbral	Documentos de 1, 5 y 10 MB	Criterio RF-5 (≤ 10 s)
Usabilidad	Evaluar facilidad de uso y comprensión de flujos	Pruebas moderadas con 5 adultos mayores y cuestionario SUS	NFR-USAB-1 a 4, 3.1.1
Accesibilidad	Verificar conformidad WCAG 2.1 AA	Contraste, ARIA, teclado, lector de pantalla, objetivos táctiles	3.1.1, NFR-USAB-1
Compatibilidad	Asegurar funcionamiento en navegadores y dispositivos definidos	Chrome, Firefox, Safari y Edge (2 últimas versiones); móvil, tablet y escritorio	NFR-COMPAT-1, NFR-COMPAT-2
Confiabilidad y recuperación	Verificar respaldos, restauración y tolerancia a fallos	Restauración de respaldo en ambiente QA y medición de tiempo de recuperación	NFR-SEG-7, NFR-DIS-2

3.3 Pruebas de seguridad

Tipo	Propósito	Aplicación en Atlas	Requerimientos
Análisis estático (SAST)	Detectar vulnerabilidades en el código fuente	Revisión automática del código React y Express en cada commit	NFR-SEG-5
Análisis de dependencias (SCA)	Detectar librerías con vulnerabilidades o licencias incompatibles	npm audit y Dependabot/Snyk sobre el stack declarado	Sección 4, Ley 17.336
Análisis dinámico (DAST)	Detectar vulnerabilidades en la aplicación en ejecución	Escaneo de la API y SPA en QA	NFR-SEG-5
Pruebas de control de acceso	Verificar autorización por rol y por empresa	Intentos de escritura con editor y acceso a recursos de otra empresa (IDOR)	NFR-SEG-4, RB-2, RB-4
Pruebas de autenticación y sesión	Validar login, fuerza bruta, expiración y revocación de tokens	Reutilización de JWT tras logout, tokens alterados, política de contraseñas	RF-1, NFR-SEG-2, NFR-SEG-9
Pruebas criptográficas	Verificar TLS y cifrado en reposo	Configuración TLS, redirección HTTP $\rightarrow$ HTTPS, campos bancarios cifrados en BD	NFR-SEG-1, NFR-SEG-3
Pruebas de penetración	Simular un atacante con autorización formal	Checklist OWASP ASVS nivel 2 antes de producción	Criterio 3.3.1

Tipo	Propósito	Aplicación en Atlas	Requerimientos
Pruebas de auditoría y logs	Confirmar que los eventos críticos quedan registrados sin datos sensibles	Revisión de registros tras cada acción crítica	RF-6.1, NFR-SEG-6

3.4 Justificación de la selección

Elegimos esta combinación según el riesgo del producto:

- Atlas es transaccional y multiempresa, así que un error de autorización expone datos de terceros. Por eso las pruebas de control de acceso tienen prioridad alta y se automatizan.
- El público adulto mayor requiere pruebas de usabilidad con usuarios reales; ninguna herramienta automática las reemplaza.
- Los umbrales de NFR-PERF solo se pueden demostrar con pruebas de carga medibles.
- La protección de datos personales exige evidencia de cifrado, trazabilidad y ausencia de vulnerabilidades críticas.

4. Estrategia de pruebas

4.1 Enfoque

Usamos un **enfoque mixto basado en riesgo**. Lo repetitivo (unitarias, API, control de acceso, rendimiento, regresión y análisis de seguridad automatizado) se automatiza y corre en el pipeline de integración continua. Lo que necesita criterio humano (usabilidad, accesibilidad con lector de pantalla, pruebas exploratorias y pentest manual) se ejecuta a mano.

Aplicamos **shift-left**: calidad y seguridad se verifican desde el inicio del desarrollo y no solo al final. Esto va en línea con la seguridad por diseño de la Ley 21.663 y la responsabilidad proactiva de la Ley 21.719.

4.2 Niveles y etapas del proceso

Tomando como referencia ISO/IEC/IEEE 29119, el proceso tiene cinco etapas:

Etapas	Actividades	Entregable
1. Planificación	Análisis de la ERS, identificación de riesgos, definición de alcance, criterios y recursos	Plan de pruebas (este documento)
2. Diseño	Redacción de casos de prueba, datos de prueba y matriz de trazabilidad	Casos de prueba y matriz

Etapa	Actividades	Entregable
3. Preparación del entorno	Configuración de ambiente QA, datos anonimizados, herramientas y pipeline CI	Ambiente QA operativo
4. Ejecución	Pruebas unitarias → integración/API → sistema → no funcionales → seguridad → UAT	Registro de ejecución y defectos
5. Cierre	Evaluación de criterios de salida, informe final y lecciones aprendidas	Informe de resultados

4.3 Priorización basada en riesgo

La prioridad se obtiene de probabilidad × impacto, considerando además qué tan sensible es el dato involucrado.

Prioridad	Riesgo	Requerimientos	Justificación
P1 – Crítica	Acceso a datos de otra empresa o escritura con rol editor	RF-3.2, NFR-SEG-4, RB-2, RB-4	Exposición de datos personales y bancarios; incumplimiento legal
P1 – Crítica	Suplantación de sesión o token no revocado	RF-1.1, RF-1.2, NFR-SEG-9	Compromete todo el sistema
P1 – Crítica	Inyección SQL, XSS o CSRF	NFR-SEG-5	Pérdida de integridad y confidencialidad
P1 – Crítica	Enlace compartido de documento accesible sin control	RF-5.5	Fuga de contratos
P2 – Alta	Falta de registro de auditoría	RF-6.1, NFR-SEG-6	Sin trazabilidad no se demuestra cumplimiento
P2 – Alta	Cálculo incorrecto del estado del contrato	RF-5.4	Decisiones de negocio erróneas
P2 – Alta	Incumplimiento de umbrales de rendimiento	NFR-PERF-1 a 3	Afecta la operación diaria
P3 – Media	Barreras de usabilidad y accesibilidad	NFR-USAB, 3.1.1	Exclusión de adultos mayores
P3 – Media	Diferencias entre navegadores	NFR-COMPAT	Experiencia inconsistente

4.4 Criterios de entrada

- ERS v1.1 aprobada y dudas de la sección 2.4 resueltas o asumidas formalmente.
- Build desplegado en ambiente QA con TLS habilitado y migraciones aplicadas.
- Pruebas unitarias del sprint aprobadas en el pipeline.
- Datos de prueba ficticios o anonimizados cargados (nunca datos reales de clientes).

- Herramientas configuradas y accesos entregados al equipo de QA.
- Autorización escrita para ejecutar pruebas de penetración.

4.5 Criterios de salida

- 100 % de los casos P1 ejecutados y aprobados.
- ≥ 95 % de los casos P2 y P3 aprobados, sin defectos abiertos de severidad crítica o alta.
- 0 vulnerabilidades críticas o altas abiertas (OWASP ZAP, SAST, SCA y pentest).
- Umbrales de NFR-PERF cumplidos en la prueba de carga.
- SUS ≥ 70 y sin bloqueos mayores en pruebas con adultos mayores.
- Matriz de trazabilidad con cobertura del 100 % de los requerimientos esenciales.
- Informe de resultados aprobado por QA Lead y Product Owner.

4.6 Criterios de suspensión y reanudación

Las pruebas se suspenden si el ambiente QA no está disponible, si un defecto bloqueante impide ejecutar más del 30 % de los casos planificados o si se detecta una vulnerabilidad crítica que exponga datos. Se reanudan cuando el defecto se corrige y se verifica con una prueba de confirmación, seguida de la regresión del módulo afectado.

4.7 Gestión de defectos

Cada defecto se registra en Jira con severidad (crítica, alta, media, baja), pasos de reproducción, evidencia y requerimiento asociado. El ciclo es: nuevo → asignado → en corrección → listo para verificar → cerrado o reabierto. Los defectos de seguridad se manejan con visibilidad restringida.

5. Criterios de aceptación transversales

Estos criterios aplican a todos los casos, además del criterio propio de cada uno. Un caso queda **aprobado** solo si obtiene el resultado esperado y no incumple ninguno de los puntos siguientes.

5.1 Criterios funcionales

- El sistema ejecuta la operación completa y persiste los datos correctamente en PostgreSQL.
- Las validaciones se aplican en backend, aunque existan en frontend; una petición directa a la API con datos inválidos debe ser rechazada con HTTP 400 o 422.
- Las eliminaciones son lógicas y solicitan confirmación previa al usuario (criterio RF-4).

- Toda operación crítica genera un registro de auditoría con usuario, empresa, acción, recurso, fecha y hora (RF-6.1).

5.2 Criterios de seguridad

- Un recurso no autorizado responde HTTP 401 (sin autenticación) o 403 (sin permiso), sin revelar si el recurso existe.
- Ninguna respuesta de la API ni mensaje de error expone contraseñas, hashes, tokens, trazas de pila o consultas SQL.
- Los datos bancarios se almacenan cifrados y no se escriben en logs en texto plano.
- Toda comunicación se realiza por HTTPS; las peticiones HTTP se redirigen o rechazan.

5.3 Criterios no funcionales

- Operaciones CRUD simples con percentil 95 inferior a 300 ms bajo carga normal (NFR-PERF-1).
- Página principal cargada en menos de 2 segundos en perfil de red móvil (NFR-PERF-2).
- Tasa de error inferior al 1 % con 200 usuarios concurrentes (NFR-PERF-3).
- Subida y descarga de documentos en 10 segundos o menos (criterio RF-5).
- Sin incumplimientos WCAG 2.1 AA de nivel crítico; contraste mínimo 4,5:1 en texto normal.

5.4 Criterios de reglas de negocio

- Solo usuarios vinculados en empresa_usuarios ven o editan datos de su empresa (RB-2).
- El rol editor no puede crear, editar ni eliminar (RB-4); el administrador tiene acceso completo (RB-5).
- Un contrato pertenece a un único cliente (RB-3).
- El correo principal no se repite entre empresas mientras la política esté activa (RB-1).

5.5 Severidad de defectos

Severidad	Definición	Efecto sobre la aceptación
Crítica	Pérdida o exposición de datos, caída del sistema, vulneración de seguridad	Bloquea la liberación
Alta	Función esencial no disponible sin alternativa	Bloquea la liberación

Severidad	Definición	Efecto sobre la aceptación
Media	Función afectada con alternativa disponible	Se acepta con plan de corrección
Baja	Defecto visual o de redacción	Se acepta y se agenda

6. Herramientas utilizadas

Herramienta	Tipo de prueba	Uso en Atlas	Fundamento
Jest + Supertest	Unitarias e integración de API	Pruebas de servicios y endpoints Express	Estándar en el ecosistema Node.js; se integra al pipeline CI
React Testing Library	Unitarias de componentes	Formularios de login, registro y clientes	Prueba componentes como los usa el usuario, favoreciendo accesibilidad
Swagger (OpenAPI) + Postman/Newman	Pruebas de API y contrato	Colección de endpoints críticos con aserciones	Exigido en el criterio de la sección 3.1.2 de la ERS
Playwright	End-to-end y compatibilidad	Flujos completos en Chromium, Firefox y WebKit (Safari)	Cubre los navegadores de NFR-COMPAT-1 y emulación móvil
BrowserStack	Compatibilidad en dispositivos reales	Safari iOS, tablets Android y Edge	Complementa la emulación con dispositivos físicos
k6 (o Apache JMeter)	Carga, estrés y picos	200 usuarios concurrentes y medición de p95	Umbrales configurables que validan NFR-PERF automáticamente
Google Lighthouse	Rendimiento frontend y accesibilidad	Tiempo de carga en móvil y auditoría básica	Mide directamente NFR-PERF-2
axe DevTools / WAVE	Accesibilidad	Contraste, ARIA y estructura semántica	Verificación automatizada frente a WCAG 2.1 AA
NVDA	Accesibilidad manual	Navegación con lector de pantalla	Detecta barreras que las herramientas automáticas no capturan
System Usability Scale (SUS)	Usabilidad	Cuestionario tras sesiones con adultos mayores	Entrega el puntaje cuantitativo que exige NFR-USAB
OWASP ZAP	DAST	Escaneo de la API y la SPA en QA	Herramienta abierta alineada con OWASP Top 10
Burp Suite Community	Pentest manual	Manipulación de JWT, IDOR, CSRF y enlaces compartidos	Permite probar control de acceso con precisión

Herramienta	Tipo de prueba	Uso en Atlas	Fundamento
SonarQube / Semgrep	SAST y calidad de código	Vulnerabilidades y deuda técnica en cada commit	Seguridad desde el desarrollo (shift-left)
npm audit + Dependabot	SCA	Vulnerabilidades y licencias de dependencias	Controla OWASP A06 y la Ley 17.336
SSL Labs / testssl.sh	Pruebas criptográficas	Versión y configuración de TLS	Evidencia objetiva de NFR-SEG-1
GitHub Actions	Integración continua	Ejecución automática de suites en cada push	Regresión constante y trazabilidad de ejecuciones
Jira + Xray	Gestión de pruebas y defectos	Casos, ejecuciones, defectos y trazabilidad	Centraliza la evidencia de cumplimiento

7. Recursos necesarios

7.1 Recursos humanos

Rol	Cantidad	Responsabilidades
QA Lead	1	Planificación, priorización, seguimiento de criterios de salida e informe final
Analista QA funcional	2	Diseño y ejecución de casos funcionales, API, regresión y UAT
Ingeniero de automatización	1	Scripts Playwright, Jest, Newman y k6; integración con CI
Analista de seguridad	1	SAST, DAST, pentest autorizado y revisión de cifrado
Especialista UX/accesibilidad	1	Pruebas con adultos mayores, SUS y auditoría WCAG
Desarrolladores backend y frontend	2	Corrección de defectos y soporte de pruebas unitarias
DevOps	1	Ambientes, TLS, respaldos y monitoreo
Product Owner (CreaLab)	1	Resolución de ambigüedades y aprobación de UAT
Asesor legal (apoyo)	1	Validación de criterios de protección de datos
Usuarios representativos	5	Adultos mayores para pruebas de usabilidad (criterio 3.1.1)

7.2 Recursos técnicos

- **Software:** Node.js 20 LTS, React 19.1.1, Express 4.19.2, PostgreSQL 16, pg 8.12.0, jsonwebtoken 9.0.2 y las herramientas de la sección 6.
- **Navegadores:** Chrome, Firefox, Safari y Edge en sus dos últimas versiones estables.

- **Dispositivos:** notebook Windows 11 y macOS; smartphone Android e iPhone; tablet Android y iPad.
- **Resoluciones de referencia:** 360 px, 768 px, 1366 px y 1920 px.
- **Red:** perfiles de conexión 4G y 3G simulados para NFR-PERF-2.

7.3 Entornos de prueba

Entorno	Uso	Características
Desarrollo (DEV)	Pruebas unitarias y de componentes	Local o contenedores Docker; datos sintéticos
Integración continua (CI)	Regresión automatizada, SAST y SCA	GitHub Actions en cada push y pull request
QA / Staging	Pruebas de sistema, API, seguridad, rendimiento y usabilidad	Réplica de producción con TLS, storage interno y BD cifrada; datos ficticios o anonimizados
Preproducción	UAT y prueba final de carga	Configuración idéntica a producción

En ningún ambiente de prueba se usan datos personales reales. Así aplicamos el principio de minimización de la Ley 21.719 y evitamos que un ambiente con menos controles termine filtrando información.

8. Cronograma de ejecución

Proponemos un cronograma de referencia de seis semanas, siguiendo las etapas de la sección 4.2.

Semana	Etapas	Actividades principales	Responsable	Hito
1	Planificación	Análisis ERS, riesgos, aclaración de ambigüedades, aprobación del plan	QA Lead, PO	Plan aprobado
2	Diseño y preparación	Casos de prueba, datos de prueba, matriz de trazabilidad, ambiente QA y pipeline	Analistas QA, DevOps	Ambiente QA listo
3	Ejecución funcional	Unitarias, API, integración y sistema de RF-1 a RF-6; reglas de negocio	Analistas QA, Automatización	Funcionales P1 aprobados
4	Ejecución no funcional	Carga y estrés, compatibilidad, accesibilidad y usabilidad con adultos mayores	Automatización, UX	Informe de rendimiento y SUS
5	Seguridad	SAST, SCA, DAST, pentest autorizado, verificación de cifrado y auditoría	Analista de seguridad	0 hallazgos críticos

Semana	Etapas	Actividades principales	Responsable	Hito
6	Regresión, UAT y cierre	Reprueba de defectos, regresión completa, UAT e informe final	QA Lead, PO	Aceptación formal

Las pruebas automatizadas de regresión, SAST y SCA se ejecutan de manera continua desde la semana 2 hasta el cierre.

9. Diseño de casos de prueba

Diseñamos trece casos que cubren requerimientos funcionales, reglas de negocio y requerimientos no funcionales de seguridad, rendimiento, usabilidad, accesibilidad y compatibilidad. Los códigos de requerimiento son los de la ERS v1.1.

CP-01 – Inicio de sesión con credenciales válidas

ID	CP-01
Nombre	Inicio de sesión con credenciales válidas
Requerimiento asociado	RF-1.1, NFR-SEG-2, NFR-SEG-9
Tipo de prueba	Funcional – Sistema / API
Prioridad	P1
Descripción	Verificar que un usuario registrado se autentique con nombre de usuario y contraseña y reciba un JWT de corta vigencia y un refresh token.
Precondiciones	Usuario activo registrado y asociado a una empresa; ambiente QA con TLS.
Pasos	1. Abrir la página de login por HTTPS. 2. Ingresar nombre de usuario y contraseña válidos. 3. Presionar "Ingresar". 4. Inspeccionar la respuesta de POST /api/auth/login.
Datos de entrada	usuario: admin.pyme01 / contraseña: Atlas#Prueba2026
Resultado esperado	HTTP 200; se entrega un access token JWT con expiración ≤ 15 minutos y un refresh token; el usuario es dirigido al dashboard de su empresa; la respuesta no contiene el hash de la contraseña.
Criterios de aceptación	Token válido y firmado; tiempo de respuesta < 300 ms; login registrado en auditoría; la contraseña en BD corresponde a un hash bcrypt (prefijo \$2b\$, costo ≥ 10).

CP-02 – Revocación del token al cerrar sesión

ID	CP-02
Nombre	Invalidación de sesión y revocación de token tras logout
Requerimiento asociado	RF-1.2, NFR-SEG-9
Tipo de prueba	Seguridad – Autenticación y sesión
Prioridad	P1
Descripción	Comprobar que, tras cerrar sesión, ni el access token ni el refresh token puedan reutilizarse.
Precondiciones	Sesión iniciada con CP-01; tokens copiados desde la herramienta de pruebas.
Pasos	1. Ejecutar POST /api/auth/logout.

	2. Repetir GET /api/empresas/:id/clients con el access token anterior. 3. Ejecutar POST /api/auth/refresh con el refresh token anterior. 4. Enviar un JWT con la firma alterada.
Datos de entrada	Tokens obtenidos en CP-01; JWT modificado manualmente en Burp Suite.
Resultado esperado	Las peticiones de los pasos 2, 3 y 4 responden HTTP 401; el frontend redirige al login.
Criterios de aceptación	Ningún token revocado o manipulado concede acceso; el logout queda auditado; no se exponen detalles del motivo del rechazo.

CP-03 – Registro de usuario y creación de empresa

ID	CP-03
Nombre	Registro de usuario nuevo y creación de empresa con rol administrador
Requerimiento asociado	RF-2.1, RF-2.2, RF-2.3, RB-1, restricción 2.4 (política de contraseñas)
Tipo de prueba	Funcional – Sistema (end-to-end)
Prioridad	P2
Descripción	Validar el flujo de registro, la política de contraseñas, la creación de empresa y la asignación automática del rol administrador.
Precondiciones	Correo de prueba no registrado; servicio de correo de QA disponible.
Pasos	1. Ingresar a Registro. 2. Intentar registrar con contraseña débil. 3. Registrar con contraseña válida. 4. Confirmar el correo. 5. Crear empresa con nombre, dirección, teléfono y correo. 6. Revisar el rol asignado en Gestión de Usuarios.
Datos de entrada	Contraseña débil: atlas123; válida: Crea#Lab2026pyme; empresa: "Ferretería Los Andes SpA", correo contacto@losandes.test
Resultado esperado	El paso 2 muestra un mensaje claro indicando el requisito incumplido; el registro válido crea el usuario y la empresa, y el usuario queda como administrador y es dirigido al dashboard.
Criterios de aceptación	Contraseñas con menos de 12 caracteres o sin complejidad son rechazadas en frontend y backend; el primer usuario tiene rol administrador; un segundo registro con el mismo correo principal es rechazado (RB-1).

CP-04 – Rol editor sin permisos de escritura

ID	CP-04
Nombre	Restricción de escritura para el rol editor en interfaz y API
Requerimiento asociado	RF-3.2, RB-4, NFR-SEG-4

Tipo de prueba	Seguridad – Control de acceso (autorización)
Prioridad	P1
Descripción	Verificar que un editor solo pueda visualizar, incluso si intenta operaciones de escritura directamente contra la API.
Precondiciones	Usuario con rol editor en la empresa A; al menos un cliente y un contrato existentes.
Pasos	1. Iniciar sesión como editor. 2. Verificar que la interfaz no muestre botones de crear, editar ni eliminar. 3. Con el token del editor, ejecutar POST /api/contratos. 4. Ejecutar PUT y DELETE sobre un cliente existente. 5. Intentar POST /api/contratos/:id/documentos.
Datos de entrada	Token del usuario editor.pyme01; cuerpo JSON de contrato válido.
Resultado esperado	Los pasos 3, 4 y 5 responden HTTP 403 y no modifican la base de datos; el intento queda registrado.
Criterios de aceptación	0 operaciones de escritura exitosas con rol editor; los datos permanecen íntegros; la verificación ocurre en backend y no depende de ocultar botones.

CP-05 – Aislamiento de datos entre empresas

ID	CP-05
Nombre	Acceso a clientes de otra empresa por manipulación de identificador (IDOR)
Requerimiento asociado	RB-2, NFR-SEG-4, NFR-SEG-8
Tipo de prueba	Seguridad – Control de acceso / Cumplimiento normativo
Prioridad	P1
Descripción	Confirmar que un administrador de la empresa A no pueda consultar ni modificar datos de la empresa B modificando identificadores en la URL o en el cuerpo de la petición.
Precondiciones	Empresas A y B con clientes cargados; usuario administrador solo vinculado a la empresa A.
Pasos	1. Iniciar sesión como administrador de A. 2. Ejecutar GET /api/empresas/{idB}/clients. 3. Ejecutar GET /api/clientes/{idClienteB}. 4. Ejecutar PUT sobre un contrato de B. 5. Revisar el registro de auditoría.
Datos de entrada	idEmpresaA = 101, idEmpresaB = 102, idClienteB = 5530
Resultado esperado	Todas las peticiones responden HTTP 403 o 404 sin revelar datos de B; se registra el intento de acceso no autorizado.
Criterios de aceptación	Ningún dato personal o bancario de B se expone; el comportamiento se repite con IDs secuenciales y aleatorios; evidencia archivada como respaldo de

	cumplimiento de la Ley 19.628 / 21.719.
--	---

CP-06 – Creación, validación y eliminación lógica de cliente

ID	CP-06
Nombre	CRUD de cliente con validación de campos y eliminación lógica
Requerimiento asociado	RF-4.1, RF-4.2, RF-4.3, NFR-USAB-3
Tipo de prueba	Funcional – Sistema
Prioridad	P2
Descripción	Validar la creación de clientes con datos correctos e incorrectos, el listado con paginación y filtros, y la eliminación lógica con confirmación.
Precondiciones	Sesión iniciada como administrador.
Pasos	1. Crear un cliente con datos válidos. 2. Intentar crear un cliente con RUT inválido y teléfono con letras. 3. Listar clientes y filtrar por nombre. 4. Eliminar el cliente y cancelar en la confirmación. 5. Eliminar nuevamente y confirmar. 6. Consultar la base de datos.
Datos de entrada	Válido: "Comercial Ñuñoa Ltda.", RUT 76.123.456-0, fono +56 9 8765 4321. Inválido: RUT 12.345.678-X, fono "98ab76"
Resultado esperado	El cliente válido se guarda y aparece en el listado; los datos inválidos muestran mensajes claros por campo; la cancelación no elimina; la confirmación oculta el cliente del listado sin borrarlo físicamente.
Criterios de aceptación	Validaciones activas también en la API (HTTP 422); registro con marca de eliminación (deleted_at o equivalente); acciones auditadas; paginación correcta.

CP-07 – Cálculo del estado de un contrato

ID	CP-07
Nombre	Estado activo, por vencer y expirado según fechas
Requerimiento asociado	RF-5.1, RF-5.4, RB-3
Tipo de prueba	Funcional – Unitaria y sistema (partición de equivalencia y valores límite)
Prioridad	P2
Descripción	Verificar que el estado del contrato se calcule correctamente según su fecha de inicio y término, incluidos los valores límite.
Precondiciones	Cliente existente; umbral "por vencer" definido en 30 días (supuesto de la sección 2.4); fecha del sistema controlada.
Pasos	1. Crear contratos con las combinaciones de fechas indicadas.

	2. Revisar el estado mostrado en la lista y en el detalle. 3. Intentar asociar un mismo contrato a dos clientes.
Datos de entrada	Fecha de referencia: 16/09/2026. A: 01/01/2026–31/12/2026. B: 01/01/2026–16/10/2026 (30 días). C: 01/01/2026–15/09/2026. D: término anterior al inicio.
Resultado esperado	A = activo; B = por vencer; C = expirado; D rechazado por validación; el paso 3 no se permite.
Criterios de aceptación	100 % de combinaciones con el estado correcto, incluidos los límites; no se permiten fechas incoherentes; un contrato tiene un solo cliente.

CP-08 – Carga de documento, almacenamiento y auditoría

ID	CP-08
Nombre	Carga de documento en contrato con validación de formato, tiempo y registro
Requerimiento asociado	RF-5.2, RF-5.3, RF-6.1, NFR-SEG-5
Tipo de prueba	Integración (frontend–API–storage–BD) y rendimiento
Prioridad	P2
Descripción	Validar que se adjunte un documento permitido, se almacene en storage interno referenciado en BD, se rechacen archivos no permitidos y se registre la acción.
Precondiciones	Contrato existente sin documento; sesión de administrador.
Pasos	1. Adjuntar un PDF de 5 MB y medir el tiempo. 2. Descargar el documento y medir el tiempo. 3. Intentar adjuntar un archivo .exe renombrado como .pdf. 4. Intentar adjuntar un segundo documento al mismo contrato. 5. Revisar la tabla de documentos y el registro de auditoría.
Datos de entrada	contratoservicios.pdf (5 MB); malwaretest.pdf (ejecutable renombrado, inofensivo); 2do_anexo.docx
Resultado esperado	El PDF se sube y descarga en ≤ 10 s; la BD guarda la ruta del archivo, no el binario; el archivo falso se rechaza por tipo real; el sistema aplica la regla de un documento por contrato; se registran subida y descarga.
Criterios de aceptación	Tiempos ≤ 10 s; validación por tipo MIME real; archivo accesible solo por usuarios autorizados; registros de auditoría con usuario, fecha y acción.

CP-09 – Enlace compartido de documento

ID	CP-09
Nombre	Seguridad del enlace para compartir documentos
Requerimiento asociado	RF-5.5, NFR-SEG-4, NFR-SEG-8
Tipo de prueba	Seguridad – Control de acceso

Prioridad	P1
Descripción	Verificar que el enlace generado sea impredecible, tenga vigencia y pueda revocarse.
Precondiciones	Contrato con documento; sesión de administrador.
Pasos	1. Generar enlace para compartir. 2. Abrirlo en una ventana privada. 3. Modificar un carácter del token del enlace. 4. Revocar el enlace y volver a abrirlo. 5. Esperar la expiración configurada y abrirlo.
Datos de entrada	Vigencia configurada de prueba: 5 minutos.
Resultado esperado	El enlace válido permite solo la descarga del documento indicado; los pasos 3, 4 y 5 niegan el acceso; cada uso queda auditado.
Criterios de aceptación	Token de al menos 128 bits de entropía; sin acceso tras revocar o expirar; el enlace no permite navegar a otros documentos.

CP-10 – Protección contra inyección SQL, XSS y CSRF

ID	CP-10
Nombre	Validación y saneamiento de entradas frente a ataques comunes
Requerimiento asociado	NFR-SEG-5, RF-4.3, 3.1.2
Tipo de prueba	Seguridad – DAST y pentest manual
Prioridad	P1
Descripción	Comprobar que los formularios y endpoints rechacen o neutralicen cargas maliciosas.
Precondiciones	Autorización formal de pentest; ambiente QA aislado; OWASP ZAP y Burp Suite configurados.
Pasos	1. Ingresar carga SQLi en el login y en el filtro de clientes. 2. Guardar un cliente con script en la descripción y abrir su detalle. 3. Enviar una petición de modificación desde un origen externo sin token CSRF. 4. Ejecutar escaneo activo con OWASP ZAP.
Datos de entrada	' OR '1'='1' --; <script>alert('xss')</script>;
Resultado esperado	No hay acceso ni alteración de datos; el script se muestra como texto y no se ejecuta; la petición externa se rechaza; los errores no revelan información técnica.
Criterios de aceptación	0 vulnerabilidades críticas o altas en ZAP; consultas parametrizadas; cabeceras CSP y CORS restrictivas; resultado documentado en checklist OWASP ASVS.

CP-11 – Carga con 200 usuarios concurrentes

ID	CP-11
Nombre	Prueba de carga sobre operaciones CRUD y página principal
Requerimiento asociado	NFR-PERF-1, NFR-PERF-2, NFR-PERF-3, NFR-DIS-1
Tipo de prueba	No funcional – Rendimiento (carga)
Prioridad	P2
Descripción	Medir tiempos de respuesta y tasa de error bajo la concurrencia definida en la ERS.
Precondiciones	Ambiente de preproducción equivalente a producción; 20.000 clientes y 50.000 contratos ficticios; script k6 validado.
Pasos	1. Rampa de 0 a 200 usuarios virtuales en 5 minutos. 2. Mantener 200 usuarios durante 20 minutos (login, listar, crear y editar clientes). 3. Medir la página principal con Lighthouse en perfil móvil. 4. Registrar CPU, memoria y conexiones de BD.
Datos de entrada	Script carga_atlas.js; distribución 60 % lectura / 40 % escritura.
Resultado esperado	p95 < 300 ms en CRUD simples; carga de página < 2 s; tasa de error < 1 %; sin caídas del servicio.
Criterios de aceptación	Umbrales cumplidos en tres ejecuciones consecutivas; informe de k6 y Lighthouse adjunto como evidencia.

CP-12 – Usabilidad y accesibilidad con adultos mayores

ID	CP-12
Nombre	Flujo cliente → contratos evaluado por adultos mayores
Requerimiento asociado	NFR-USAB-1, NFR-USAB-2, NFR-USAB-3, NFR-USAB-4, 3.1.1
Tipo de prueba	No funcional – Usabilidad y accesibilidad
Prioridad	P3
Descripción	Evaluar si usuarios mayores completan tareas clave sin ayuda y si la interfaz cumple WCAG 2.1 AA.
Precondiciones	5 participantes de 60 años o más con consentimiento informado; datos ficticios; guion de tareas; axe DevTools y NVDA instalados.
Pasos	1. Pedir a cada participante buscar un cliente y abrir sus contratos. 2. Pedir crear un cliente con un error intencional y corregirlo. 3. Registrar tiempo, errores y solicitudes de ayuda. 4. Aplicar cuestionario SUS. 5. Auditar las pantallas con axe y navegar solo con teclado y NVDA.
Datos de entrada	Guion de 3 tareas; cuestionario SUS de 10 ítems.

Resultado esperado	Las tareas se completan sin bloqueos; los mensajes de error se entienden; el flujo es cliente → contratos; los controles son operables por teclado.
Criterios de aceptación	≥ 80 % de tareas completadas sin ayuda; SUS ≥ 70; 0 bloqueos mayores; contraste ≥ 4,5:1; objetivos táctiles ≥ 44 × 44 px; 0 errores críticos en axe.

CP-13 – Compatibilidad entre navegadores y dispositivos

ID	CP-13
Nombre	Funcionamiento responsivo en navegadores y dispositivos soportados
Requerimiento asociado	NFR-COMPAT-1, NFR-COMPAT-2
Tipo de prueba	No funcional – Compatibilidad
Prioridad	P3
Descripción	Verificar que login, gestión de clientes y visualización de documentos funcionen de forma consistente en la matriz definida.
Precondiciones	Suite Playwright de flujos esenciales; acceso a BrowserStack.
Pasos	1. Ejecutar la suite en Chrome, Firefox, Edge y WebKit (dos últimas versiones). 2. Repetir en iPhone (Safari), tablet Android y iPad. 3. Comparar capturas en 360 px, 768 px y 1366 px.
Datos de entrada	Matriz de 4 navegadores × 2 versiones × 3 resoluciones.
Resultado esperado	Flujos completados en todas las combinaciones; sin elementos superpuestos ni scroll horizontal en móvil.
Criterios de aceptación	100 % de la matriz sin defectos bloqueantes o altos; diferencias visuales menores documentadas.

10. Matriz de trazabilidad

La matriz vincula cada requerimiento de la ERS con los casos que lo verifican, el tipo de prueba y la norma o estándar relacionado. Los requerimientos que todavía no tienen caso detallado se cubren con la suite indicada y quedan anotados para la iteración 2.

10.1 Requerimientos funcionales y reglas de negocio

Requerimiento	Descripción breve	Casos de prueba	Tipo de prueba	Control normativo / estándar
RF-1.1	Autenticación con usuario y contraseña	CP-01	Funcional, API	OWASP A07; ISO/IEC 27001 A.8.5
RF-1.2	Cierre de sesión y revocación de tokens	CP-02	Seguridad	OWASP A07; ASVS V3
RF-2.1	Registro rápido de usuario	CP-03	Funcional E2E	Ley 21.719 (licitud y finalidad)
RF-2.2	Creación de empresa	CP-03	Funcional E2E	ISO/IEC 25010 (adecuación funcional)
RF-2.3	Primer usuario como administrador	CP-03	Funcional E2E	Principio de mínimo privilegio
RF-3.1	Invitar o crear usuarios y asignar rol	Suite regresión API (iteración 2: CP-14)	Funcional, API	ISO/IEC 27001 A.5.18
RF-3.2	Editor solo visualiza	CP-04	Seguridad (autorización)	OWASP A01; Ley 19.628
RF-3.3	Modificar o eliminar usuarios	Suite regresión API (iteración 2: CP-15)	Funcional	ISO/IEC 27001 A.5.18
RF-4.1	Crear clientes	CP-06	Funcional	ISO/IEC 25010
RF-4.2	Editar, eliminar y listar con filtros	CP-06	Funcional	Ley 21.719 (supresión, trazabilidad)
RF-4.3	Validación de campos	CP-06, CP-10	Funcional, seguridad	OWASP A03
RF-5.1	Crear contratos por cliente	CP-07	Funcional	ISO/IEC 25010
RF-5.2	Adjuntar documento en formatos permitidos	CP-08	Integración	OWASP A04 (diseño inseguro)
RF-5.3	Storage interno referenciado en BD	CP-08	Integración	ISO/IEC 27001 A.8.10

Requerimiento	Descripción breve	Casos de prueba	Tipo de prueba	Control normativo / estándar
RF-5.4	Estado del contrato por fechas	CP-07	Funcional, unitaria	ISO/IEC 25010 (corrección)
RF-5.5	Enlace para compartir documento	CP-09	Seguridad	OWASP A01; Ley 19.628
RF-6.1	Auditoría de acciones críticas	CP-01, CP-04, CP-05, CP-06, CP-08, CP-09	Funcional, seguridad	OWASP A09; Ley 21.719 (responsabilidad proactiva)
RB-1	Correo principal único	CP-03	Regla de negocio	Integridad de datos
RB-2	Acceso solo a usuarios de la empresa	CP-05	Seguridad	Ley 19.628; Ley 21.719; OWASP A01
RB-3	Contrato asociado a un solo cliente	CP-07	Regla de negocio	Integridad referencial
RB-4	Editor con permisos de lectura	CP-04	Seguridad	OWASP A01
RB-5	Administrador con acceso completo	CP-03, CP-06, CP-08	Funcional	Mínimo privilegio

10.2 Requerimientos no funcionales

Requerimiento	Descripción breve	Casos de prueba	Tipo de prueba	Control normativo / estándar
NFR-SEG-1	TLS obligatorio	CP-01 (precondición), verificación SSL Labs	Seguridad criptográfica	OWASP A02; ISO/IEC 27001 A.8.24
NFR-SEG-2	Hash bcrypt	CP-01	Seguridad	OWASP A02
NFR-SEG-3	Cifrado de datos sensibles en reposo	Revisión de BD en QA (iteración 2: CP-16)	Seguridad	Ley 19.628; ISO/IEC 27001 A.8.24
NFR-SEG-4	Control de acceso por rol en backend	CP-04, CP-05, CP-09	Seguridad	OWASP A01
NFR-SEG-5	Protección CSRF, XSS, SQLi	CP-08, CP-10	Seguridad (DAST, pentest)	OWASP A03; ASVS V5

Requerimiento	Descripción breve	Casos de prueba	Tipo de prueba	Control normativo / estándar
NFR-SEG-6	Gestión de logs segura	CP-08 y revisión de logs	Seguridad	OWASP A09; ISO/IEC 27001 A.8.15
NFR-SEG-7	Respaldo y recuperación	Prueba de restauración en QA (iteración 2: CP-17)	Confiabilidad	ISO/IEC 27001 A.8.13; Ley 21.663
NFR-SEG-8	Cumplimiento de protección de datos	CP-05, CP-09	Cumplimiento	Ley 19.628; Ley 21.719
NFR-SEG-9	Sesión mediante JWT	CP-01, CP-02	Seguridad	OWASP A07
NFR-PERF-1	CRUD < 300 ms	CP-01, CP-11	Rendimiento	ISO/IEC 25010 (eficiencia)
NFR-PERF-2	Página principal < 2 s en móvil	CP-11	Rendimiento	ISO/IEC 25010
NFR-PERF-3	200 usuarios concurrentes	CP-11	Carga	ISO/IEC 25010
NFR-USAB-1	Tipografía, contraste y controles grandes	CP-12	Usabilidad, accesibilidad	WCAG 2.1 AA
NFR-USAB-2	Flujos claros de registro	CP-03, CP-12	Usabilidad	ISO/IEC 25010 (usabilidad)
NFR-USAB-3	Ayuda contextual y errores amigables	CP-06, CP-12	Usabilidad	WCAG 3.3 (asistencia en la entrada)
NFR-USAB-4	Flujo cliente → contratos	CP-12	Usabilidad	ISO/IEC 25010
NFR-DIS-1	Disponibilidad 99,5 %	CP-11 y monitoreo	Confiabilidad	ISO/IEC 25010 (disponibilidad)
NFR-DIS-2	Mantenimiento y migración segura	Prueba de migración (iteración 2)	Mantenibilidad	ISO/IEC 27001 A.8.32
NFR-COMPAT-1	Navegadores modernos	CP-13	Compatibilidad	ISO/IEC 25010
NFR-COMPAT-2	Responsivo móvil y tablet	CP-13	Compatibilidad	ISO/IEC 25010 (portabilidad)
3.1.1	Accesibilidad de interfaz	CP-12	Accesibilidad	WCAG 2.1 AA
3.1.2	API REST validada con Swagger	CP-01, CP-02, CP-04, CP-10	API	OpenAPI; OWASP API Security Top 10

11. Análisis de cobertura y coherencia del plan

11.1 Cobertura cuantitativa

Grupo de requerimientos	Total en ERS	Con caso de prueba detallado	Cubiertos por suite o actividad planificada	Cobertura total
Funcionales (RF)	17	15	2 (RF-3.1, RF-3.3)	100 %
Reglas de negocio (RB)	5	5	0	100 %
Seguridad (NFR-SEG)	9	7	2 (NFR-SEG-3, NFR-SEG-7)	100 %
Rendimiento (NFR-PERF)	3	3	0	100 %
Usabilidad (NFR-USAB)	4	4	0	100 %
Disponibilidad (NFR-DIS)	2	1	1 (NFR-DIS-2)	100 %
Compatibilidad (NFR-COMPAT)	2	2	0	100 %
Total	42	37 (88 %)	5 (12 %)	100 %

Todos los requerimientos de la ERS quedan trazados. El 88 % ya tiene un caso documentado; el resto se cubre con suites de regresión o actividades puntuales que detallaremos como casos en la iteración 2.

11.2 Distribución por tipo de prueba

Tipo	Casos	Porcentaje
Funcional (unitaria, integración, sistema, API)	CP-01, CP-03, CP-06, CP-07, CP-08	38 %
Seguridad	CP-02, CP-04, CP-05, CP-09, CP-10	38 %
No funcional (rendimiento, usabilidad, accesibilidad, compatibilidad)	CP-11, CP-12, CP-13	23 %

Las pruebas de seguridad tienen más peso a propósito: cada riesgo P1 de la sección 4.3 tiene al menos un caso asociado, y todos involucran datos personales o bancarios.

11.3 Coherencia con los objetivos y estándares

- **Con los objetivos del proyecto:** cada objetivo del plan (sección 1.3) tiene casos asociados. El aislamiento entre empresas se verifica en CP-04 y CP-05; la protección de datos en CP-02, CP-09 y CP-10; el rendimiento en CP-11 y la experiencia de adultos mayores en CP-12.
- **Con ISO/IEC 25010:** las ocho características de calidad tienen al menos un criterio y una forma de medición (sección 2.1). Mantenibilidad y portabilidad tienen menor profundidad porque la ERS no define métricas explícitas para ellas.
- **Con OWASP Top 10:** se cubren A01, A02, A03, A05, A06, A07 y A09. A08 (integridad de software y datos) y A10 (SSRF) quedan cubiertas solo por el análisis automatizado, ya que la ERS no describe funciones que descarguen recursos externos.
- **Con el marco legal chileno:** las evidencias de CP-05, CP-09 y los registros de auditoría permiten demostrar medidas de seguridad y control de acceso, que es lo que exige la responsabilidad proactiva de la Ley 21.719. El uso exclusivo de datos ficticios en ambientes de prueba aplica el principio de minimización.

11.4 Brechas identificadas y acciones

Brecha	Impacto	Acción propuesta
La ERS no define tamaño máximo de archivo ni umbral de "vence"	Criterios de aceptación ambiguos en CP-07 y CP-08	Validar supuestos (10 MB y 30 días) con el Product Owner
Fuente de 12 px en la ERS	Riesgo de incumplir NFR-USAB-1 y WCAG para adultos mayores	Proponer cambio a 16 px antes del diseño final
Contradicción entre RF-4.1 y RB-4 sobre quién crea clientes	Posibles defectos de autorización	Aclaración formal; CP-04 prueba la interpretación restrictiva
Sin requerimientos de consentimiento, derechos del titular ni reporte de brechas	Riesgo de incumplimiento de la Ley 21.719	Recomendar nuevos requerimientos y casos para la iteración 2
Sin métrica para disponibilidad en ambiente de prueba	NFR-DIS-1 solo verificable en operación	Monitoreo con alertas desde preproducción
Casos pendientes de detalle (RF-3.1, RF-3.3, NFR-SEG-3, NFR-SEG-7, NFR-DIS-2)	Cobertura documental parcial	Redactar CP-14 a CP-18 en la iteración 2

11.5 Conclusión

Atlas es un sistema multiempresa que maneja datos personales y bancarios de terceros, y el plan responde a eso. La estrategia basada en riesgo pone el mayor esfuerzo en control de

acceso y protección de datos, sin dejar de lado el rendimiento ni la usabilidad para adultos mayores, que la ERS marca como prioritarios.

La trazabilidad entre requerimientos, casos y normas sirve para detectar defectos y, al mismo tiempo, para reunir evidencia de cumplimiento frente a la Ley 19.628, la Ley 21.719 y los estándares ISO/IEC y OWASP. Las brechas que encontramos en la ERS quedan documentadas para la siguiente iteración del caso semestral.